

AutoTricks

Supabase Backend Implementation Report

Database schema, security (RLS / grants / Storage), trusted backend functions, end-to-end verification, issues encountered and final project state

Item	Value
Supabase project	Autotricks Lead&Quotation
Project ref	extsmeyxnzhvhcmwyvbi
Organization	tulscggliifhodbuzes
Region / status	ap-south-1 / ACTIVE_HEALTHY
PostgreSQL	17.6.1.166 (engine 17, GA channel)
Source schema	AutoTricks_Master_Schema_v1.0.sql (957 lines)
Report date	2026-09-13
Final test result	144 PASS / 0 FAIL (full end-to-end suite, final run)
Overall verdict	Backend ready for frontend integration (with the open items listed in Section 20)

Contents

- 1. Executive summary
- 2. Scope, constraints and instructions followed
- 3. Work method and chronological timeline
- 4. Phase 1 - Initial inspection of the Supabase project
- 5. Review of the supplied schema and live defect probe
- 6. Migrations applied
- 7. Schema additions (beyond v1.0)
- 8. Database inventory (verified on the live database)
- 9. Integrity and immutability guards (business rules in the database)
- 10. Security: grants, RLS policies, SECURITY DEFINER
- 11. Audit trail and notifications
- 12. Workflow RPC functions
- 13. Storage buckets and Storage policies
- 14. Edge Functions
- 15. TypeScript types
- 16. Testing - methodology and all results
- 17. Supabase advisors (before and after)
- 18. Problems encountered and how they were resolved
- 19. Cleanup and final database state
- 20. Open items, limitations and recommendations
- 21. Frontend integration guide
- 22. Files delivered
- 23. Final verdict

1. Executive summary

The AutoTricks backend was implemented directly in the connected Supabase project extsmeyxnzhhvcmwyvbi. The project was confirmed to be completely empty at the start (no migrations, tables, enums, functions, policies, buckets or Edge Functions), which proves the previous agent's migration attempt had not applied anything.

The supplied AutoTricks_Master_Schema_v1.0.sql was read in full and applied unchanged as migration 1. It applied without SQL errors. Instead of trusting it, the live database was then probed with realistic role-switched attacks. That probe confirmed 15 real business/security defects in v1.0 (for example: clients could see DRAFT quotations, admins could mark a quotation ACCEPTED on the client's behalf, items could be added to a signed quotation, a vehicle could be transferred to another client, audit entries could be forged, anon could execute every public function). These were fixed in six additional migrations that keep the v1.0 architecture intact and only add to it.

Deliverables:

- 7 migrations applied and recorded in supabase_migrations (the original schema + 6 hardening migrations).
- 17 tables (16 original + vehicle_correction_requests), all with RLS enabled; 13 enums; 44 triggers; 66 indexes; 34 table RLS policies; 6 Storage policies.
- 16 workflow RPC functions for sensitive state transitions (quotation lifecycle, signing, service jobs, additional-work approval, change/correction requests).
- 4 private Storage buckets (signatures, quotation-pdfs, signed-quotation-pdfs, service-documents) with independent Storage RLS.
- 2 Edge Functions deployed and HTTP-tested: submit-service-request (public website form) and admin-invite-user (controlled portal access).
- Append-only audit trail and in-app + queued email notifications written by triggers (email failure cannot roll back business operations).
- TypeScript types generated from the live database.
- A re-runnable end-to-end SQL test suite: final run 144 PASS / 0 FAIL, covering all 20 business invariants requested.

Not completed (explicitly): the email sending worker (queue exists; provider not chosen), PDF generation, and a live success-path test of admin-invite-user (requires a real admin session and SMTP). Details in Section 20.

2. Scope, constraints and instructions followed

Instruction	How it was handled
Operate only on extsmeyxnzhhvcmwyvbi; do not touch Hynox Campus	Project confirmed via get_project before any change; every tool call targeted only this ref.
Read the entire SQL file before executing	The file was initially blocked (outside working dir, see Section 18). After the user copied it into D:\autotricks_web, all 957 lines were read and reviewed before migration 1.
Do not rewrite the architecture / do not simplify without confirmation	v1.0 applied unchanged. All fixes are additive migrations. No table or enum was removed. Changes to v1.0 behaviour are listed in Sections 6-10 for confirmation.
Inspect actual state; do not assume previous migration succeeded or failed	Inventory queries showed an empty project (Section 4).
Stop on SQL errors, fix minimally, verify no partial state	No migration failed. Test-script errors were fixed and re-run (Section 18).
Verify the actual database, not the migration output	Catalog inventory queries, role-switched probes, HTTP calls and advisors were used after every phase.
RLS on public tables; clients only see own data; no broad anon access	Verified by tests (Section 16) and HTTP (anon REST calls return 401).
Use TO authenticated / TO anon explicitly	All 40 policies are TO authenticated. No anon policies exist because anon has no business access at all.
No user_metadata for authorization; no unnecessary SECURITY DEFINER	Authorization reads public.profiles only. SECURITY DEFINER used only where required (Section 10.4), all with search_path pinned.
UPDATE RLS needs SELECT visibility	Every UPDATE policy has a matching SELECT policy; tested (profile name, notifications mark-read, admin updates).
Storage RLS separate from DB RLS	Separate storage.objects policies created and tested independently.
Email failure must not roll back business	notify helpers catch and log failures; tested (N3).

Instruction	How it was handled
Audit logs append-only; clients cannot manipulate	Trigger blocks UPDATE/DELETE even for the table owner; no client insert/select.
Public submission through controlled endpoint	submit-service-request Edge Function; anon has no table grants.
Do not touch landing page	No frontend/landing page files were created or modified. Only supabase/ files were written.
Generate TypeScript types	Generated and saved to supabase/types/database.types.ts.

3. Work method and chronological timeline

#	Phase / step	What happened	Outcome
1	Load tools, locate schema file	Supabase MCP tools loaded. Read of C:\Users\ADMIN\Downloads\AutoTricks_Master_Schema_v1.0.sql blocked by the blockReadsOutsideWorkingDirectories setting.	Stopped and asked the user instead of bypassing the setting.
2	Phase 1 - Inspect project (parallel)	get_project, list_migrations, list_tables, list_edge_functions, catalog query (enums, functions, triggers, policies, buckets, extensions, auth users).	Project empty; previous attempt applied nothing.
3	Read schema	User copied file into D:\autotricks_web; full file read and reviewed.	Reviewed; suspected defects noted.
4	Phase 2 - Apply v1.0	File copied to supabase/migrations/20260913000001_master_schema_v1_0.sql and applied via apply_migration.	Success, no errors.
5	Phase 3 - Verify structure	Inventory: 16 tables RLS on, 13 enums, 30 FK / 16 check / 8 unique / 16 PK, 47 indexes, 13 triggers, 8 functions, 42 policies, no anon table grants, anon EXECUTE on all 8 functions.	Baseline recorded.
6	Advisors baseline	Security: 8 x function_search_path_mutable. Performance: 11 unindexed FKs, 23 unused indexes.	Recorded.
7	Recursion hypothesis	Suspected is_admin() RLS recursion on profiles. First probe inconclusive (did not prove role switch), second probe with current_user showed role=authenticated and correct visibility.	Hypothesis DISPROVED; reported the correction to the user.
8	Phase 4 - Live defect probe	19-case rolled-back probe as CLIENT and ADMIN.	15 confirmed defects (Section 5).
9	Write hardening migrations	Migrations 002-007 written locally.	Files saved.
10	Apply 002-007 sequentially	Applied one by one to keep history order identical to local files (004 must precede 006 because it revokes EXECUTE).	All 6 succeeded.
11	Structure re-verification	Full catalog inventory after hardening.	17 tables, 44 triggers, 66 indexes, 34+6 policies, anon nothing.
12	Edge Function research	search_docs on verify_jwt with new API keys.	Public endpoint must use verify_jwt=false; user-JWT endpoint may keep true.
13	Phase 8 - Full E2E run #1	~140 checks.	3 FAIL - later proven to be test-assertion bugs; part of report truncated.
14	Deploy Edge Functions + focused re-test	Both functions deployed ACTIVE. Focused SQL re-test with row counts and ground-truth read-back.	All 21 focused checks PASS; the 3 FAILs were false alarms.
15	HTTP tests, advisors, types	15 curl requests; security/performance advisors; generate_typescript_types.	All HTTP results as expected; advisors clean except intentional warnings.
16	Cleanup test row	Deleted the single real row created by the HTTP valid-submission test (SR-2026-00006).	Deleted; 1 audit row remains (append-only).
17	Phase 11 - Final full E2E run	First attempt failed to compile (RAISE placeholder bug in the report line); fixed and re-run.	144 PASS / 0 FAIL.
18	Reset sequences, final state check	Reference sequences restarted at 1 (guarded: only if no business data).	Next numbers: SR/QT/JOB-2026-00001.
19	Documentation	supabase/README.md with integration guide; this report.	Delivered.

4. Phase 1 - Initial inspection of the Supabase project

Area inspected	Result
Project identity	id/ref extsmeyxnzhvcmwyvbi, name 'Autotricks Lead&Quotation', org tulsclgglifhoduhez, ap-south-1, ACTIVE_HEALTHY, Postgres 17.6.1.166, created 2026-09-10
Migrations	None ([])
public tables	None
public enums/types	None
public functions	None
public triggers	None
RLS policies (public + storage)	None
Storage buckets	None
Edge Functions	None
auth.users	0 users
Extensions	plpgsql, pg_stat_statements, uuid-oss, pgcrypto, supabase_vault (Supabase defaults)
Roles	postgres (bypassrls=true, not superuser), service_role (bypassrls=true), authenticated/anon (no bypass), supabase_storage_admin
Conclusion	The previous migration attempt did NOT apply anything. Clean slate; no partial state to repair.

5. Review of the supplied schema and live defect probe

5.1 Migration 1 result

AutoTricks_Master_Schema_v1.0.sql was applied exactly as supplied (migration 20260913142400 master_schema_v1_0). It completed without any SQL error.

5.2 Hypothesis that was tested and disproved

During review it looked like public.is_admin() / current_client_id() (SECURITY INVOKER functions reading profiles, while the profiles policy itself calls is_admin()) would cause infinite RLS recursion. This was tested on the live database with an ADMIN and a CLIENT user and role=authenticated confirmed via current_user. Result: CLIENT saw 1 profile and 1 client, ADMIN saw 2 and 2 - no recursion. The claim was withdrawn and reported to the user as a correction. The helpers were still moved to hardened SECURITY DEFINER functions in a private schema for performance and search_path safety, not as a bug fix.

5.3 Live defect probe on v1.0 (rolled back)

A rolled-back PL/pgSQL probe created an admin, two client users, two clients, vehicles, requests, a quotation with DRAFT/SENT/signed revisions, a job and pending additional work, then attempted each abuse as the real role. Results and the fix applied:

Test	Attempt	v1.0 result	Fix (migration)
T1	Client reads DRAFT revisions	CONFIRMED DEFECT (1 visible)	Revision/item SELECT policies hide DRAFT from clients (004)
T2	Client inserts change request with status ACCEPTED + admin_response	CONFIRMED DEFECT	Direct insert revoked; client_request_quotation_change RPC; guard trigger (003/004/006)
T3	Admin sets revision status ACCEPTED directly	CONFIRMED DEFECT	status not writable; only client RPC can accept (004/006)
T4	Admin inserts item into a SIGNED revision	CONFIRMED DEFECT	Item guard covers INSERT/UPDATE/DELETE; DRAFT-only (003)
T5	Admin reassigns quoted service request to another client (quotation leaks)	CONFIRMED DEFECT	Client/vehicle locked once quotation exists (003)
T6	Admin transfers vehicle to another client	CONFIRMED DEFECT	vehicles_guard trigger + no client_id update grant (003/004)
T7	Admin self-approves additional work	CONFIRMED DEFECT	Approval only by owning CLIENT profile, via RPC (003/006)
T8	Admin starts unapproved additional work	CONFIRMED DEFECT	Work item guard blocks IN_PROGRESS/COMPLETED before APPROVED (003)
T9	Admin edits a SENT revision	CONFIRMED DEFECT	Content editable only in DRAFT (003)

Test	Attempt	v1.0 result	Fix (migration)
T10	Job created with another client's vehicle	CONFIRMED DEFECT	service_jobs_guard; direct job insert revoked (003/004)
T12	Client edits text of own notification	CONFIRMED DEFECT	Column grant update(is_read, read_at) only (004)
T13	Admin forges audit entry with another actor	CONFIRMED DEFECT	Audit insert revoked; trigger-written only; append-only guard (003/004/005)
T15	Phone request recorded with a different creator	CONFIRMED DEFECT	Policy + trigger: PHONE and created_by = auth.uid() (003/004)
T18	Admin fabricates a WEBSITE request	CONFIRMED DEFECT	Data API inserts must be PHONE; WEBSITE only via Edge Function (003/004)
T19	Admin promotes client to ADMIN via Data API	CONFIRMED DEFECT	profiles update limited to full_name; roles via admin-invite-user (004)
T11	Client updates own full_name	Worked (expected)	Kept
T14	Admin rewrites original_submission	Blocked only incidentally (vehicle mismatch)	Explicit immutability guard (003)
T17	Job from unsigned revision	Inconclusive (unique key hit first)	Guard requires signature (003); retested PASS
Grants	anon EXECUTE on all 8 public functions	CONFIRMED DEFECT	EXECUTE revoked from public/anon (004)
Missing	No reference number generation; no vehicle correction table; no workflow functions; no buckets	Gap	Sequences/defaults (003), table (003), RPCs (006), Storage (007)

6. Migrations applied

Remote version	Name / local file	Purpose
20260913142400	master_schema_v1_0 (20260913000001_master_schema_v1_0.sql)	Supplied schema v1.0, unchanged.
20260913144307	notification_types (...000002)	Adds enum values QUOTATION_REJECTED, QUOTATION_CHANGE_RESPONDED, VEHICLE_CORRECTION_REQUESTED, VEHICLE_CORRECTION_RESPONDED. Separate migration because new enum values cannot be used in the transaction that adds them.
20260913144443	integrity_guards (...000003)	private schema + helpers, reference number sequences/defaults, new columns, vehicle_correction_requests table, 18 indexes, all integrity/immutability guard triggers, search_path fixes, private function privileges.
20260913144527	grants_and_rls (...000004)	Drops v1.0 policies and public helper functions; resets grants (table, sequence, function); least-privilege table/column grants; 34 policies rebuilt on private helpers.
20260913144642	audit_and_notifications (...000005)	write_audit, notify_profile/admins/client helpers; generic audit trigger on 14 tables; notification trigger on 7 tables.
20260913144855	workflow_rpcs (...000006)	require_admin/require_client; 16 workflow RPCs; EXECUTE revoked from public/anon and granted to authenticated.
20260913145002	storage (...000007)	4 private buckets with size/MIME limits; Storage helper functions; 6 storage.objects policies.

All seven are listed in supabase_migrations.schema_migrations on the live project (verified). They were applied strictly in order, one at a time.

7. Schema additions (beyond v1.0) - for confirmation

Object	Addition	Reason
quotation_revisions	updated_at, sent_at, accepted_at, accepted_by_profile_id (FK profiles), acceptance_consent_text, rejected_at, rejection_reason; check quotation_revisions_acceptance_ck (ACCEPTED requires accepted_at, accepted_by, non-empty consent)	Accept and sign are separate client steps; the signature copies accepted_at and consent text from the revision. Rejection reason needed by admin.
service_jobs	scheduled_at timestamptz	SCHEDULED status needs a scheduled time for doorstep service.

Object	Addition	Reason
documents	storage_bucket (generated, stored): QUOTATION_PDF -> quotation-pdfs, SIGNED_QUOTATION_PDF -> signed-quotation-pdfs, others -> service-documents	Frontend knows which private bucket to sign URLs from; used by storage policies.
vehicle_correction_requests (new table)	id, vehicle_id, client_id, profile_id, message (1-2000 chars), requested_changes jsonb, status (change_request_status), admin_response, responded_by, created_at, responded_at; RLS enabled	Client portal requirement 'request vehicle corrections' had no storage in v1.0.
notification_type enum	QUOTATION_REJECTED, QUOTATION_CHANGE_RESPONDED, VEHICLE_CORRECTION_REQUESTED, VEHICLE_CORRECTION_RESPONDED	Notifications for rejections and responses.
private schema	Not exposed by the Data API; holds helpers, sequences, trigger functions	Keeps SECURITY DEFINER helpers out of the public RPC surface.
Sequences + defaults	private.service_request_number_seq / quotation_number_seq / service_job_number_seq; defaults SR-YYYY-NNNNN, QT-YYYY-NNNNN, JOB-YYYY-NNNNN (year in Asia/Kolkata)	v1.0 had NOT NULL UNIQUE numbers but no generator. Quotation number never changes across revisions.
Removed from public	public.is_admin(), public.current_client_id(), public.current_profile_id() replaced by private.* equivalents	Not callable via /rest/v1/rpc; SECURITY DEFINER with pinned search_path.

8. Database inventory (verified on the live database)

8.1 Tables (17) - all RLS enabled

Table	Purpose	RLS
clients	Customer/business record (exists before portal access)	ON
profiles	Supabase Auth identity; role ADMIN/CLIENT; CLIENT -> client_id; ADMIN client_id NULL	ON
vehicles	Vehicles owned by exactly one client	ON
service_requests	Website/phone requests; original_submission preserved	ON
products	Physical product catalogue with default price	ON
quotations	Stable quotation identity (number)	ON
quotation_revisions	Versioned snapshot: totals, notes, terms, lifecycle	ON
quotation_items	Per-revision item snapshot; final_value per unit; line_total	ON
quotation_change_requests	Client negotiation requests	ON
quotation_signatures	Drawn signature record for a specific revision	ON
documents	Client documents linked to revision and/or job	ON
service_jobs	Execution of a signed quotation	ON
service_work_items	QUOTATION and ADDITIONAL work with approval evidence	ON
notifications	In-app notifications	ON
email_notifications	Email queue	ON
audit_logs	Append-only audit trail	ON
vehicle_correction_requests	Client vehicle correction requests (new)	ON

8.2 Enums (13)

Enum	Values
user_role	ADMIN, CLIENT
request_source	WEBSITE, PHONE
service_request_status	NEW, UNDER_REVIEW, QUOTATION_CREATED, QUOTATION_SENT, APPROVED, CONVERTED_TO_JOB, CANCELLED
quotation_revision_status	DRAFT, SENT, VIEWED, CHANGE_REQUESTED, ACCEPTED, REJECTED, EXPIRED, CANCELLED, SUPERSEDED
change_request_status	PENDING, ACCEPTED, PARTIALLY_ACCEPTED, REJECTED, CANCELLED
service_job_status	SCHEDULED, VEHICLE_RECEIVED, INSPECTION, WORK_IN_PROGRESS, QUALITY_CHECK, READY_FOR_DELIVERY, COMPLETED, CANCELLED
work_item_source	QUOTATION, ADDITIONAL
work_item_status	PENDING, IN_PROGRESS, COMPLETED, ON_HOLD, CANCELLED

Enum	Values
additional_work_approval_status	NOT_REQUIRED, PENDING, APPROVED, REJECTED
signature_method	DRAWN
document_type	QUOTATION_PDF, SIGNED_QUOTATION_PDF, SERVICE_REPORT, INVOICE, RECEIPT
email_delivery_status	QUEUED, SENT, FAILED
notification_type (15)	NEW_SERVICE_REQUEST, QUOTATION_SENT, QUOTATION_REVISIED, QUOTATION_CHANGE_REQUESTED, QUOTATION_ACCEPTED, QUOTATION_SIGNED, ADDITIONAL_WORK_REQUESTED, ADDITIONAL_WORK_APPROVED, ADDITIONAL_WORK_REJECTED, SERVICE_STATUS_UPDATED, SERVICE_JOB_COMPLETED, QUOTATION_REJECTED, QUOTATION_CHANGE_RESPONDED, VEHICLE_CORRECTION_REQUESTED, VEHICLE_CORRECTION_RESPONDED

8.3 Constraints

Type	Count (v1.0 -> final)	Notes
Primary keys	16 -> 17	+ vehicle_correction_requests
Foreign keys	30 -> 35	+ accepted_by_profile_id, + 4 on vehicle_correction_requests
Check constraints	16 -> 18	+ quotation_revisions_acceptance_ck, + vehicle_correction_requests_message_ck
Unique constraints	8 -> 8	request_number, quotation_number, quotations.service_request_id, (quotation_id, revision_number), signatures.quotation_revision_id, documents.storage_path, job_number, service_jobs.service_request_id

Key v1.0 checks kept and verified: profiles_client_role_ck (CLIENT needs client_id, ADMIN must not have one), service_requests_source_submission_ck, vehicles_year_ck, money/quantity checks, service_work_items_source_approval_ck, service_work_items_approval_evidence_ck, quotation_signatures_dates_ck, notifications_read_ck, service_jobs_dates_ck, documents_source_ck.

8.4 Indexes (66 total)

17 primary-key + 8 unique-constraint indexes, 23 indexes from v1.0, and 18 added in migration 003:

- idx_audit_logs_actor, idx_email_notifications_profile, idx_change_requests_profile_id, idx_quotation_items_product_id, idx_quotation_revisions_created_by, idx_quotation_revisions_accepted_by, idx_signatures_profile_id, idx_quotations_created_by, idx_service_jobs_revision_id, idx_service_requests_created_by, idx_work_items_decision_by, idx_work_items_quotation_item_id (these 11 close every 'unindexed foreign key' finding)
- idx_vehicle_corrections_vehicle_id, _client_id, _profile_id, _responded_by, _status
- idx_service_requests_website_phone on ((original_submission->>'phone'), created_at) WHERE source='WEBSITE' (website throttle lookup)

8.5 Triggers (44)

Group	Triggers
updated_at (10)	clients, profiles, vehicles, service_requests, products, quotations, quotation_items, service_jobs, service_work_items (v1.0) + quotation_revisions_set_updated_at (new)
Guards from v1.0, strengthened (4)	service_requests_validate_links (INSERT/UPDATE), documents_validate_owner (now INSERT/UPDATE/DELETE), quotation_revisions_prevent_signed_update (now UPDATE/DELETE), quotation_items_prevent_signed_update (now INSERT/UPDATE/DELETE)
New guards (9)	vehicles_guard, quotation_revisions_compute_total, quotation_items_recalculate_subtotal (AFTER), quotation_change_requests_guard, vehicle_correction_requests_guard, quotation_signatures_guard, service_jobs_guard, service_work_items_guard, audit_logs_append_only
Audit (14, AFTER)	clients, vehicles, profiles, service_requests, products, quotations, quotation_revisions, quotation_items, quotation_change_requests, quotation_signatures, documents, service_jobs, service_work_items, vehicle_correction_requests
Notification (7, AFTER)	service_requests, quotation_revisions, quotation_change_requests, quotation_signatures, service_jobs, service_work_items, vehicle_correction_requests

8.6 Functions

Schema	Function	SECURITY DEFINER	Role
public	set_updated_at	no	updated_at trigger

Schema	Function	SECURITY DEFINER	Role
public	validate_service_request_links	no	SR guard
public	validate_document_owner	no	Document guard
public	prevent_signed_revision_mutation	no	Revision guard
public	prevent_signed_item_mutation	no	Item guard + snapshot + line_total
public	16 workflow RPCs (Section 12)	yes	State transitions; authenticated only
private	is_admin, current_client_id, current_profile_id	yes	Caller identity for RLS
private	revision_client_id, service_job_client_id	yes	Ownership resolution
private	next_reference	no	Reference number default
private	guard_vehicle, compute_revision_total, guard_quotation_change_request, guard_vehicle_correction_request, guard_quotation_signature, guard_service_job, guard_service_work_item, guard_audit_log	no	Guards
private	recalculate_revision_subtotal	yes	Writes non-grantable subtotal
private	write_audit, audit_row_change	yes	Audit writer
private	notify_profile, notify_admins, notify_client, notify_row_change	yes	Notifications/email queue
private	require_admin, require_client	yes	RPC role checks
private	can_upload_signature, is_client_folder, is_registered_document	yes	Storage policy helpers

Verified: every function in public and private has search_path="" (no mutable search_path).

9. Integrity and immutability guards (business rules in the database)

These triggers apply to every write path - Data API, RPC, Edge Function and even the service_role key - so the rules cannot be bypassed by frontend bugs.

Service requests

- Vehicle requires a client; vehicle must belong to that client (INV1).
- Insert by a signed-in Data API user must be source PHONE with created_by = auth.uid() (INV20); WEBSITE rows only via the Edge Function.
- request_number, source, original_submission, created_by, created_at are immutable (INV19).
- client_id/vehicle_id cannot change once a quotation exists (prevents moving a quotation to another client).

Vehicles

- client_id can never change - a sold vehicle gets a new record for the new owner.

Quotation revisions

- total = subtotal - discount + tax, computed; negative total rejected.
- Signed revision: fully immutable, cannot be deleted (INV5).
- quotation_id, revision_number, created_by, created_at immutable; unique (quotation_id, revision_number) (INV8).
- subtotal/discount/tax/total/notes/terms editable only in DRAFT.
- sent_at, acceptance evidence and rejection evidence are write-once.
- Allowed status transitions: DRAFT->SENT|CANCELLED;
SENT->VIEWED|CHANGE_REQUESTED|ACCEPTED|REJECTED|EXPIRED|CANCELLED|SUPERSEDED;
VIEWED->(same minus VIEWED);
CHANGE_REQUESTED->ACCEPTED|REJECTED|EXPIRED|CANCELLED|SUPERSEDED; unsigned
ACCEPTED->CANCELLED|SUPERSEDED. Only DRAFT can be deleted.

Quotation items

- Insert/update/delete only while revision is DRAFT and unsigned (INV6).
- Cannot move between revisions.

- Catalogue snapshot: when catalogue_product_id is given, name/description/approximate_value/final_value default from the product at that moment; later catalogue changes never touch the item (INV7).
- line_total = round(quantity x final_value, 2); revision subtotal recalculated automatically.

Change requests / vehicle corrections

- Client and profile must own the revision/vehicle; profile must be a CLIENT of that client.
- Content immutable; status can be resolved only once (from PENDING).

Signatures

- Only for an ACCEPTED revision of the same client, by a CLIENT profile of that client.
- accepted_at and consent_text must match the revision's acceptance evidence.
- Never updated or deleted.

Documents

- storage_path must start with the owning client_id.
- Revision/job must belong to the same client; no documents on DRAFT revisions.
- SIGNED_QUOTATION_PDF requires a signed revision; rows are immutable; signed PDFs cannot be deleted (INV14 context).

Service jobs

- Created only for a request linked to client + vehicle; vehicle must be that request's vehicle of the same client (INV13).
- Revision must belong to the request and be signed; starts SCHEDULED.
- Identity immutable; status only moves forward; COMPLETED/CANCELLED are terminal; completion requires all work items COMPLETED or CANCELLED.
- started_at set when leaving SCHEDULED; completed_at set on COMPLETED; cannot be deleted.

Service work items

- QUOTATION items must reference an item of the job's signed revision.
- ADDITIONAL items must start PENDING approval, with a stated price, not started.
- Approval: only PENDING -> APPROVED/REJECTED; decision_by must be a CLIENT profile of the owning client; decision_at required; approved_value must equal final_value (INV10, INV11, INV12).
- Approval evidence immutable; agreed scope/price immutable; closed items/jobs immutable; ADDITIONAL work cannot be IN_PROGRESS/COMPLETED unless APPROVED; no deletes.

Audit logs

- Append-only for every role including the table owner; only the FK ON DELETE SET NULL of actor_profile_id is permitted.

10. Security: grants, RLS policies, SECURITY DEFINER

10.1 Role posture

- anon: no table grants, no column grants, no sequence grants, no EXECUTE on public or private functions, no Storage policies. Verified via catalog and HTTP (401 on REST insert/select/RPC).
- authenticated: least-privilege table/column grants below, always further filtered by RLS.
- service_role: full access (used only inside Edge Functions); still subject to all guard triggers.
- A signed-in user with no profile row sees nothing and cannot run any RPC (tested).
- Authorization is derived only from public.profiles (role, client_id). user_metadata is never used.

10.2 Grants to authenticated

Table	SELECT	INSERT	UPDATE	DELETE
profiles	yes	-	full_name	-
clients	yes	full_name, phone, email, address, city, state, pincode, notes, is_active	same columns	-
vehicles	yes	client_id, make, model, manufacturing_year, chassis_number, registration_number	make, model, manufacturing_year, chassis_number, registration_number	-
service_requests	yes	client_id, vehicle_id, source, original_submission, admin_notes, created_by	client_id, vehicle_id, status, admin_notes	-
products	yes	name, description, category, default_price, is_active	same columns	-
quotations	yes	- (RPC)	-	-
quotation_revisions	yes	- (RPC)	discount, tax, notes, terms	-
quotation_items	yes	quotation_revision_id, catalogue_product_id, name, description, quantity, approximate_value, final_value	catalogue_product_id, name, description, quantity, approximate_value, final_value	yes
quotation_change_requests	yes	- (RPC)	- (RPC)	-
quotation_signatures	yes	- (RPC)	-	-
documents	yes	client_id, quotation_revision_id, service_job_id, document_type, storage_path	-	-
service_jobs	yes	- (RPC)	scheduled_at	-
service_work_items	yes	- (RPC)	status	-
notifications	yes	-	is_read, read_at	-
email_notifications	yes	-	-	-
audit_logs	yes	-	-	-
vehicle_correction_requests	yes	- (RPC)	- (RPC)	-

10.3 RLS policies on public tables (34, all TO authenticated)

Table	Policy	Cmd	Rule
profiles	profiles_select_own_or_admin	SELECT	id = auth.uid() OR is_admin
profiles	profiles_update_own_or_admin	UPDATE	USING/WITH CHECK id = auth.uid() OR is_admin
clients	clients_select_admin_or_own	SELECT	is_admin OR id = current_client_id
clients	clients_insert_admin / clients_update_admin	INSERT/UPDATE	is_admin
vehicles	vehicles_select_admin_or_own	SELECT	is_admin OR client_id = current_client_id
vehicles	vehicles_insert_admin / vehicles_update_admin	INSERT/UPDATE	is_admin
service_requests	service_requests_select_admin_or_own	SELECT	is_admin OR client_id = current_client_id
service_requests	service_requests_insert_admin_phone	INSERT	is_admin AND source='PHONE' AND created_by = auth.uid()
service_requests	service_requests_update_admin	UPDATE	is_admin
products	products_select_portal_users	SELECT	is_admin OR (is_active AND caller has a profile)
products	products_insert_admin / products_update_admin	INSERT/UPDATE	is_admin
quotations	quotations_select_admin_or_own	SELECT	is_admin OR request belongs to caller's client
quotation_revisions	revisions_select_admin_or_own_sent	SELECT	is_admin OR (status <> DRAFT AND owned)
quotation_revisions	revisions_update_admin	UPDATE	is_admin (+ DRAFT-only guard)
quotation_items	quotation_items_select_admin_or_own_sent	SELECT	is_admin OR (revision not DRAFT AND owned)

Table	Policy	Cmd	Rule
quotation_items	quotation_items_insert_admin / _update_admin / _delete_admin	INSERT/UPDATE/DELETE	is_admin (+ DRAFT-only guard)
quotation_change_requests	change_requests_select_admin_or_owns	SELECT	is_admin OR client_id = current_client_id
quotation_signatures	signatures_select_admin_or_owns	SELECT	is_admin OR client_id = current_client_id
documents	documents_select_admin_or_owns	SELECT	is_admin OR client_id = current_client_id
documents	documents_insert_admin	INSERT	is_admin
service_jobs	service_jobs_select_admin_or_owns	SELECT	is_admin OR request owned
service_jobs	service_jobs_update_admin	UPDATE	is_admin
service_work_items	work_items_select_admin_or_owns	SELECT	is_admin OR job owned
service_work_items	work_items_update_admin	UPDATE	is_admin
notifications	notifications_select_own / notifications_update_own	SELECT/UPDATE	profile_id = auth.uid()
email_notifications	email_notifications_select_admin_or_owns	SELECT	is_admin OR profile_id = auth.uid()
audit_logs	audit_logs_select_admin	SELECT	is_admin
vehicle_correction_requests	vehicle_corrections_select_admin_or_owns	SELECT	is_admin OR client_id = current_client_id

UPDATE-RLS rule: every table with an UPDATE policy also has a SELECT policy covering the same rows. Verified by tests A3 (admin updates request), C4 (client updates own name) and N1 (client marks notifications read).

10.4 SECURITY DEFINER justification

- private.is_admin / current_client_id / current_profile_id / revision_client_id / service_job_client_id: read profiles and ownership without re-entering RLS; they only describe the caller or resolve ownership.
- 16 workflow RPCs: must perform transitions on columns no client/admin can write directly; each checks role (require_admin/require_client), ownership and state, and returns 'not found' for other clients' records to avoid enumeration.
- Audit/notification/subtotal triggers: write rows the invoking role has no grant for.
- Storage helpers: evaluate ownership inside storage policies.
- All have SET search_path = '' and fully qualified names. EXECUTE revoked from PUBLIC; RPCs granted to authenticated only; helpers only to authenticated/service_role in the non-exposed private schema.

11. Audit trail and notifications

11.1 Audit actions written by triggers

Entity	Actions
clients	CLIENT_CREATED
vehicles	VEHICLE_CREATED, VEHICLE_IDENTITY_CHANGED (before/after identity)
profiles	PROFILE_CREATED, PROFILE_ACCESS_CHANGED; USER_INVITED (written by admin-invite-user with inviter as actor)
service_requests	SERVICE_REQUEST_CREATED, SERVICE_REQUEST_STATUS_CHANGED, SERVICE_REQUEST_LINKED
products	PRODUCT_CREATED, PRODUCT_PRICE_CHANGED, PRODUCT_ACTIVATED, PRODUCT_DEACTIVATED
quotations	QUOTATION_CREATED
quotation_revisions	QUOTATION_REVISION_CREATED, QUOTATION_SENT, QUOTATION_VIEWED, QUOTATION_ACCEPTED, QUOTATION_REJECTED, QUOTATION_REVISION_STATUS_CHANGED, QUOTATION_PRICE_CHANGED (discount/tax)
quotation_items	QUOTATION_ITEM_ADDED, QUOTATION_ITEM_REMOVED, QUOTATION_PRICE_CHANGED (quantity/final_value)
quotation_change_requests	QUOTATION_CHANGE_REQUESTED, QUOTATION_CHANGE_REQUEST_RESPONDED
quotation_signatures	QUOTATION_SIGNED
documents	DOCUMENT_CREATED
service_jobs	SERVICE_JOB_CREATED, SERVICE_STATUS_CHANGED

Entity	Actions
service_work_items	ADDITIONAL_WORK_CREATED, ADDITIONAL_WORK_APPROVED, ADDITIONAL_WORK_REJECTED, WORK_ITEM_STATUS_CHANGED
vehicle_correction_requests	VEHICLE_CORRECTION_REQUESTED, VEHICLE_CORRECTION_RESPONDED

actor_profile_id = the caller's profile (auth.uid()) is preserved inside RPCs, so client actions are attributed to the client and admin actions to the admin - verified). Entries carry JSON metadata (from/to values).

11.2 Notifications

Event	Recipient	Type
Website service request created	All admins	NEW_SERVICE_REQUEST
Revision sent (rev 1 / later)	Client's portal users	QUOTATION_SENT / QUOTATION_REVISED
Revision accepted / rejected	All admins	QUOTATION_ACCEPTED / QUOTATION_REJECTED
Change request created / responded	Admins / requesting client	QUOTATION_CHANGE_REQUESTED / QUOTATION_CHANGE_RESPONDED
Revision signed	All admins	QUOTATION_SIGNED
Job created / status changed / completed	Client	SERVICE_STATUS_UPDATED / SERVICE_JOB_COMPLETED
Additional work added	Client	ADDITIONAL_WORK_REQUESTED
Additional work approved / rejected	All admins	ADDITIONAL_WORK_APPROVED / ADDITIONAL_WORK_REJECTED
Vehicle correction requested / responded	Admins / requesting client	VEHICLE_CORRECTION_REQUESTED / VEHICLE_CORRECTION_RESPONDED

Each notification inserts an in-app row and queues an email_notifications row (status QUEUED) to the recipient's auth email. Both inserts are wrapped in exception handlers that raise a WARNING instead of an error, so a notification or email-queue failure never rolls back the business operation (tested N3). Delivery is independent and must be done by a worker (not yet built, Section 20).

12. Workflow RPC functions

Called from the frontend with supabase.rpc(name, params). All return jsonb, are SECURITY DEFINER with search_path "", EXECUTE granted to authenticated only.

Function	Parameters	Checks and effects
admin_create_quotation	p_service_request_id, p_notes?, p_terms?	Admin only; request must be linked to client + vehicle, not CANCELLED/CONVERTED; one quotation per request. Creates quotation (QT number) + revision 1 DRAFT; request -> QUOTATION_CREATED.
admin_create_quotation_revision	p_quotation_id	Admin; blocked if any revision signed or a DRAFT exists. New DRAFT = latest revision + 1, copies discount/tax/notes/terms and all items (snapshot).
admin_send_quotation_revision	p_revision_id	Admin; DRAFT with at least one item; no signed revision. Other open revisions -> SUPERSEDED; this -> SENT (sent_at); request -> QUOTATION_SENT; client notified.
admin_close_quotation_revision	p_revision_id, p_status (CANCELLED EXPIRED)	Admin; guard enforces valid transition and unsigned.
admin_respond_quotation_change_request	p_change_request_id, p_status, p_response?	Admin; PENDING only; sets response + responded_at; client notified.
admin_respond_vehicle_correction	p_request_id, p_status, p_response?	Admin; PENDING only; sets responded_by/at; client notified.
admin_create_service_job	p_quotation_revision_id, p_scheduled_at?	Admin; revision must be signed; one job per request. Creates job (JOB number) using the request's vehicle, copies items as QUOTATION work items; request -> CONVERTED_TO_JOB. Never automatic.
admin_add_additional_work	p_service_job_id, p_name, p_quantity, p_final_value, p_description?, p_approximate_value?	Admin; creates ADDITIONAL item PENDING approval; client notified.
admin_update_service_job_status	p_service_job_id, p_status	Admin; forward-only, completion rules, timestamps (guard).
client_mark_quotation_viewed	p_revision_id	Own non-DRAFT revision; SENT -> VIEWED.

Function	Parameters	Checks and effects
client_request_quotation_change	p_revision_id, p_message (1-2000)	Own revision in SENT/VIEWED/CHANGE_REQUESTED; creates change request; revision -> CHANGE_REQUESTED; admins notified.
client_accept_quotation_revision	p_revision_id, p_consent_given (must be true), p_consent_text (10-5000)	Own revision in SENT/VIEWED/CHANGE_REQUESTED -> ACCEPTED with accepted_at, accepted_by, consent text; admins notified.
client_reject_quotation_revision	p_revision_id, p_reason?	Own open revision -> REJECTED with reason; admins notified.
client_sign_quotation_revision	p_revision_id, p_signature_path	Own ACCEPTED, unsigned revision, accepted by the same user; path must be {client_id}/{revision_id}/{name}.png and exist in bucket signatures owned by caller. Inserts signature (consent + accepted_at from revision, signed_at now); leftover DRAFTs -> CANCELLED; request -> APPROVED.
client_decide_additional_work	p_work_item_id, p_approve, p_expected_final_value, p_note?	Own ADDITIONAL PENDING item; expected price must equal stated price (prevents approving a changed price). Records status, approved_value, decision_by, decision_at, note; rejection cancels the item.
client_request_vehicle_correction	p_vehicle_id, p_message, p_requested_changes? (object < 4KB)	Own vehicle; creates PENDING request; admins notified.

13. Storage buckets and Storage policies

Bucket	Public	Size limit	MIME types	Path	Writers
signatures	no	512 KB	image/png	{client_id}/{revision_id}/{file}.png	Client (own ACCEPTED unsigned revision, accepted by self), write-once
quotation-pdfs	no	10 MB	application/pdf	{client_id}/...	Admin
signed-quotation-pdfs	no	10 MB	application/pdf	{client_id}/...	Admin, write-once
service-documents	no	20 MB	pdf, png, jpeg, webp	{client_id}/...	Admin

storage.objects policy	Cmd	Rule
autotricks_admin_read_objects	SELECT	4 buckets AND is_admin
autotricks_client_read_own_objects	SELECT	4 buckets AND first folder = caller's client_id
autotricks_client_upload_signature	INSERT	bucket signatures AND can_upload_signature(name)
autotricks_admin_upload_documents	INSERT	3 document buckets AND is_admin AND first folder is an existing client
autotricks_admin_update_unregistered_documents	UPDATE	quotation-pdfs/service-documents AND is_admin AND file not registered in documents
autotricks_admin_delete_unregistered_documents	DELETE	quotation-pdfs/service-documents AND is_admin AND file not registered

There are no UPDATE/DELETE policies for signatures or signed-quotation-pdfs at all, so no authenticated user can replace or delete them. No policy grants anon anything (HTTP list of the signatures bucket as anon returned an empty array). Downloads should use signed URLs.

14. Edge Functions

14.1 Evaluation

Sensitive transactional workflows were implemented as database RPCs (atomic, one round trip, enforced by the same triggers, testable as real roles). Edge Functions were used only where the database alone is not appropriate: an anonymous public endpoint that must not receive table grants, and an operation requiring the Auth admin API. PDF generation and email delivery are outstanding (Section 20).

14.2 submit-service-request (ACTIVE, version 1, verify_jwt = false)

- Purpose: public 'book a service' form. Anonymous visitors never touch core tables.

- Methods: OPTIONS (204 CORS), POST only (405 otherwise). Optional ALLOWED_ORIGINS env (default *). Body limit 16 KB; invalid JSON -> 400.
- Honeypot field company_website: if filled -> 202 {ok:true} with nothing stored.
- Validation (422 with per-field messages): customer_name 2-100; phone digits/+ 10-15 after removing spaces/dashes/brackets; email optional, valid, lowercased; car_make and car_model 1-60; manufacturing_year optional integer 1886..current+1; chassis_number optional A-Z0-9 5-25 (uppercased, spaces/dashes removed); registration_number optional A-Z0-9 4-15 (normalized); current_location 3-300; service_description 5-2000.
- Throttle: max 5 WEBSITE requests per phone per hour -> 429.
- Insert with service role: source WEBSITE, status NEW, client/vehicle NULL, original_submission = validated fields + submitted_at. Returns 201 {request_number, submitted_at}. Admins notified by trigger.
- Why verify_jwt=false: Supabase docs state the platform verify_jwt check only understands JWTs; new publishable keys are not JWTs, so a public endpoint must disable it and validate in code.

14.3 admin-invite-user (ACTIVE, version 1, verify_jwt = true)

- Purpose: the only path to a profile. No public admin signup.
- Auth: Bearer token validated with auth.getUser (works with any signing key type); caller must have profiles.role = ADMIN (403 otherwise; 401 for missing/invalid token).
- Body: email, full_name (2-100), role CLIENT|ADMIN, client_id (required and existing+active for CLIENT, must be null for ADMIN), redirect_to optional (or INVITE_REDIRECT_URL env).
- Sends auth.admin.inviteUserByEmail; 409 if the email already exists; inserts profile with service role; if profile insert fails the invited auth user is deleted (rollback); writes USER_INVITED audit entry with the inviter as actor. Returns 201 {user_id, email, role, client_id}.

14.4 HTTP test results (real calls to the deployed functions and APIs)

#	Request	Expected	Actual	Result
a	OPTIONS submit-service-request	204	204	PASS
b	GET submit-service-request	405	405 Method not allowed	PASS
c	POST invalid JSON	400	400 Invalid JSON body	PASS
d	POST invalid fields	422 + field errors	422 with 7 field messages	PASS
e	POST honeypot filled	202, nothing stored	202 {ok:true}	PASS
f	POST valid submission (apikey header)	201 + number	201 SR-2026-00006 (test row later deleted)	PASS
g	POST with Authorization: Bearer publishable key	Reaches function	422 (function executed)	PASS
g2	POST with legacy anon JWT	Reaches function	422 (function executed)	PASS
h	admin-invite-user without Authorization	401	401 Authentication required	PASS
i	admin-invite-user with legacy anon JWT	401	401 Invalid or expired session	PASS
j	admin-invite-user with publishable key bearer	401	401 Invalid or expired session	PASS
k	REST anon INSERT service_requests	denied	401 permission denied for table service_requests	PASS
l	REST anon SELECT clients	denied	401 permission denied for table clients	PASS
m	REST anon RPC admin_create_quotation	denied	401 permission denied for function	PASS
n	Storage anon list signatures bucket	no objects	200 []	PASS

15. TypeScript types

Generated with generate_typescript_types from the live database after the schema was final and saved to supabase/types/database.types.ts. It contains all 17 tables (Row/Insert/Update and relationships, including the new columns and vehicle_correction_requests), the 16 RPC signatures with argument and return types, all 13 enums with the 4 added notification values, and the Tables/TablesInsert/TablesUpdate/Enums helpers plus Constants. The private schema is intentionally not exposed. PostgrestVersion 14.5.

16. Testing - methodology and all results

16.1 Methodology

- Tests run inside the live database as the real roles, switching SET LOCAL ROLE (anon / authenticated / service_role / postgres) and request.jwt.claims exactly like PostgREST does, so RLS, column grants, policies and triggers behave as in production.
- Fake auth users are inserted inside the transaction; the whole run ends with RAISE EXCEPTION containing the report, so everything is rolled back and nothing persists (only sequence values are consumed).
- Expected denials are written as 'attempt; if no error -> FAIL', and row-count checks with ground-truth read-back where RLS silently filters rows.
- No passwords were used and no real users were created. HTTP tests used only the publishable/anon keys.
- Suite saved as supabase/tests/e2e_business_rules.sql (re-runnable in the SQL editor).

16.2 Test runs history

Run	Scope	Result	Notes
Recursion probe 1	ADMIN reads profiles/clients	Inconclusive	Did not prove role switch (postgres bypasses RLS).
Recursion probe 2	ADMIN + CLIENT with current_user	PASS	No recursion; hypothesis disproved.
Defect probe (v1.0)	19 attack cases	15 defects	Section 5.3.
Full E2E run 1	~140 checks	3 FAIL	INV4 price update, revision discount update, vehicle identity update flagged FAIL because the assertion treated 'no error' as a breach. RLS had filtered the updates to 0 rows. Middle of report truncated by output limit.
Focused re-test	3 cases with row counts + ground truth + truncated signature/storage/job section	21 PASS / 0 FAIL	Proved 0 rows changed: price still 1200, discount still 100, registration unchanged.
HTTP tests	15 requests	15 PASS	Section 14.4.
Final full E2E run	144 checks	144 PASS / 0 FAIL	After fixing the 3 assertions and compacting the report.

16.3 Business invariants requested (1-20)

#	Invariant	Evidence (final run)	Result
1	Vehicle cannot belong to another client through a service request	INV1 rejected: 'Service request vehicle must belong to the selected client'	PASS
2	Client cannot access another client's records	Client B sees only own client/vehicle/request/profile; none of A's quotations, revisions, items, change requests, jobs, work items	PASS
3	Client cannot modify another client's quotation	Client B change/accept on A's revision -> 'Quotation revision not found'	PASS
4	Client cannot modify quotation prices	0 rows updated; ground truth unchanged	PASS
5	Signed revision cannot be edited	Admin and even service_role blocked: 'Signed quotation revisions are immutable'	PASS
6	Signed quotation item cannot be edited	Admin and service_role blocked	PASS
7	Catalogue price changes do not alter old quotations	Product 1200->1500; item stays 1200 / line 2400	PASS
8	Revision number unique within quotation	Duplicate (q, 2) -> unique violation	PASS
9	Quotation number stable across revisions	Same QT number after revision 2	PASS
10	Additional work not executable/approved without client approval	IN_PROGRESS blocked; admin approval blocked; service_role approval by admin profile blocked	PASS
11	Approval records approving profile and timestamp	APPROVED, approved_value 800, decision_by = client, decision_at set, note stored	PASS
12	Client cannot approve another client's additional work	Client B -> 'Work item not found'; B profile as approver blocked by trigger	PASS
13	Service job cannot reference another client's vehicle	Blocked even via service_role; mixing request/revision blocked	PASS
14	Documents not accessible by another client	Client B sees 0 documents, 0 storage files, 0 signatures of A	PASS

#	Invariant	Evidence (final run)	Result
15	Anonymous users cannot write core tables	SQL + HTTP: permission denied for insert/select/update/RPC	PASS
16	Admin-only operations not possible for CLIENT	Admin RPC, create client, create product, update request all blocked	PASS
17	Clients cannot create ADMIN profiles	Insert/role change -> permission denied	PASS
18	ADMIN profiles cannot be attached to clients	profiles_client_role_ck violation	PASS
19	Website requests preserve original form data	Admin and service_role rewrite blocked; data read back intact	PASS
20	Phone requests record their admin creator	created_by = admin; wrong creator rejected	PASS

16.4 Final end-to-end run - complete list of 144 checks (all PASS)

#	Check	Result
1	INV15 anon cannot INSERT service_requests	PASS
2	anon cannot SELECT service_requests	PASS
3	anon cannot SELECT clients	PASS
4	anon cannot UPDATE products	PASS
5	anon cannot execute workflow RPCs	PASS
6	anon sees no private storage objects	PASS
7	W1 website request created NEW/WEBSITE, client_id & vehicle_id NULL	PASS
8	W2 admin in-app notification + queued email for website request	PASS
9	A1 admin sees website request	PASS
10	A2 admin created clients and vehicles	PASS
11	INV18 ADMIN profile cannot be attached to a client	PASS
12	CLIENT profile requires an existing client	PASS
13	INV1 vehicle of another client rejected on service request	PASS
14	A3 admin reviewed request and linked client + vehicle (UPDATE RLS works)	PASS
15	INV19 admin cannot rewrite original_submission	PASS
16	INV19 even service_role cannot rewrite original_submission	PASS
17	INV19 original website form data preserved	PASS
18	INV20 phone request records admin creator	PASS
19	INV20 phone request cannot claim another creator	PASS
20	staff cannot forge WEBSITE requests	PASS
21	A4 quotation created with revision 1 (DRAFT)	PASS
22	one quotation per service request	PASS
23	A5 product snapshot copied into item; line_total = quantity x final_value	PASS
24	A6 revision totals computed (subtotal 2900, total 2850)	PASS
25	C0 client cannot see DRAFT revision or its items	PASS
26	A7 revision 1 sent; request status QUOTATION_SENT	PASS
27	SENT revision content is immutable	PASS
28	items cannot be added to a SENT revision	PASS
29	admin cannot mark a quotation ACCEPTED on the client's behalf	PASS
30	INV7 catalogue price change (1200->1500) did not alter existing quotation item	PASS
31	A8 client notified QUOTATION_SENT	PASS
32	C1 client views own quotation revision 1 with 2 items	PASS
33	C2 client marked revision viewed	PASS
34	C3 client requested a change (revision CHANGE_REQUESTED)	PASS
35	INV4 client cannot modify quotation prices (0 rows updated)	PASS
36	client cannot modify revision totals (0 rows updated)	PASS
37	client cannot write change-request status/admin response	PASS
38	INV16 client cannot run admin RPCs	PASS
39	INV16 client cannot create clients	PASS
40	INV16 client cannot create products	PASS

#	Check	Result
41	INV16 client cannot update service requests (0 rows)	PASS
42	C4 client updates own profile name (UPDATE RLS with SELECT visibility)	PASS
43	INV17 client cannot change own role	PASS
44	INV2 client B sees only own client row	PASS
45	INV2 client B sees only own vehicle	PASS
46	INV2 client B sees only own service request	PASS
47	INV2 client B sees none of client A's quotations/revisions/items/change requests	PASS
48	INV2 client B sees only own profile	PASS
49	INV3 client B cannot act on A's quotation	PASS
50	INV3 client B cannot accept A's quotation	PASS
51	INV17 client cannot create ADMIN profiles	PASS
52	A9 revision 2 created (items copied)	PASS
53	INV9 quotation number stable across revisions	PASS
54	only one DRAFT revision at a time	PASS
55	A10 revision 2 renegotiated to 2750 while revision 1 snapshot stays 2850	PASS
56	INV8 revision number unique within quotation	PASS
57	A11 revision 2 sent, revision 1 SUPERSEDED	PASS
58	superseded revision cannot be accepted	PASS
59	explicit consent required to accept	PASS
60	C5 client accepted revision 2 with consent	PASS
61	signing requires the uploaded drawn signature	PASS
62	C6 client uploaded signature PNG to own signatures folder (storage INSERT policy)	PASS
63	storage: no signature upload for non-accepted revision	PASS
64	storage: client cannot upload quotation PDFs	PASS
65	storage: client B cannot upload into A's folder	PASS
66	client B cannot sign A's quotation	PASS
67	C7 signature recorded: client, profile, revision, consent text, accepted_at, signed_at, file path	PASS
68	C8 service request APPROVED after signing (no job auto-created)	PASS
69	signature cannot be replaced / signed twice	PASS
70	storage: client cannot overwrite signature file (0 rows)	PASS
71	storage: client cannot delete signature file	PASS
72	INV5 signed revision cannot be edited	PASS
73	INV6 signed quotation item cannot be edited	PASS
74	INV5 even service_role cannot change a signed revision	PASS
75	INV6 even service_role cannot change signed items	PASS
76	signature record cannot be deleted	PASS
77	INV13 job cannot use another client's vehicle	PASS
78	INV13 job cannot mix requests/revisions across clients	PASS
79	no new revision after signing	PASS
80	direct job insert blocked (workflow RPC only)	PASS
81	A12 admin created service job with 2 quotation work items; request CONVERTED_TO_JOB	PASS
82	one job per service request	PASS
83	A13 additional work added (PENDING approval)	PASS
84	INV10 additional work cannot start before approval	PASS
85	INV10 admin cannot approve on client's behalf	PASS
86	INV10 approval must come from the owning client (even via service_role)	PASS
87	INV12 another client's profile cannot be the approver	PASS
88	job cannot complete with open work items	PASS
89	A14 job VEHICLE_RECEIVED, started_at set	PASS
90	job status cannot move backwards	PASS
91	A15 client notified of additional work	PASS
92	INV12 client B cannot approve A's additional work	PASS

#	Check	Result
93	INV2 client B sees none of A's jobs/work items	PASS
94	approval must match the stated price	PASS
95	INV11 approval records status, approved value, approving profile, timestamp, note	PASS
96	approval decision is final	PASS
97	C9 client rejected second additional work (REJECTED / CANCELLED)	PASS
98	A16 admin executed 2 quotation items + approved additional work (3 rows)	PASS
99	rejected additional work cannot be executed	PASS
100	A17 job progressed through all statuses to COMPLETED	PASS
101	completed job is closed	PASS
102	storage: admin uploads must target an existing client folder	PASS
103	A18 documents registered (signed quotation PDF + service report)	PASS
104	document cannot belong to a different client than its revision	PASS
105	signed PDF requires a signed revision	PASS
106	documents cannot be replaced	PASS
107	storage: registered document file cannot be deleted	PASS
108	signed quotation document cannot be deleted (even service_role)	PASS
109	C10 client views completed service history (job COMPLETED, 4 work items)	PASS
110	C11 client sees own 2 documents and 3 storage files (signature, signed PDF, report)	PASS
111	client cannot modify service history (0 rows)	PASS
112	C12 client requested vehicle correction	PASS
113	client cannot alter verified vehicle identity (0 rows updated)	PASS
114	client sees only active catalogue products	PASS
115	INV14 client B cannot see A's documents or storage files	PASS
116	INV14 client B cannot see A's signature record	PASS
117	client B cannot request corrections on A's vehicle	PASS
118	vehicle cannot be transferred (admin)	PASS
119	A19 admin corrected vehicle identity and resolved request	PASS
120	vehicle cannot be transferred (even service_role)	PASS
121	login without profile sees nothing (no auto client creation)	PASS
122	profile-less user cannot run client RPCs	PASS
123	N1 client marks own notifications read (UPDATE RLS)	PASS
124	notification content not editable	PASS
125	N2 client emails queued independently	PASS
126	N3 notification failure is swallowed (business operation not rolled back)	PASS
127	AUDIT QUOTATION_CREATED logged	PASS
128	AUDIT QUOTATION_REVISION_CREATED logged	PASS
129	AUDIT QUOTATION_PRICE_CHANGED logged	PASS
130	AUDIT QUOTATION_ACCEPTED logged	PASS
131	AUDIT QUOTATION_SIGNED logged	PASS
132	AUDIT SERVICE_JOB_CREATED logged	PASS
133	AUDIT ADDITIONAL_WORK_CREATED logged	PASS
134	AUDIT ADDITIONAL_WORK_APPROVED logged	PASS
135	AUDIT ADDITIONAL_WORK_REJECTED logged	PASS
136	AUDIT SERVICE_STATUS_CHANGED logged	PASS
137	AUDIT SERVICE_REQUEST_CREATED logged	PASS
138	AUDIT client actions attributed to the client profile	PASS
139	AUDIT admin actions attributed to the admin profile	PASS
140	audit logs append-only (even table owner)	PASS
141	AUDIT clients cannot read audit history	PASS
142	clients cannot write audit logs	PASS
143	admin cannot forge audit entries	PASS
144	role changes only via controlled invite process	PASS

Total listed: 144 checks - PASS=144, FAIL=0.

16.5 Workflow coverage requested

Actor	Step	Result
Anonymous	Submit website service request (SQL service-role path + real HTTP)	PASS
Admin	Review request	PASS
Admin	Create client	PASS
Admin	Create vehicle	PASS
Admin	Create quotation	PASS
Admin	Create revision	PASS
Admin	Send revision	PASS
Client	View own quotation	PASS
Client	Request change	PASS
Client	Accept revision (explicit consent)	PASS
Client	Sign revision (PNG upload + RPC)	PASS
Admin	Create service job (manually, only after signature)	PASS
Admin	Add work (quotation items copied) / execute work	PASS
Admin	Add additional work	PASS
Client	Approve additional work / reject additional work	PASS
Admin	Complete service job	PASS
Client	View completed service history and documents	PASS

17. Supabase advisors (before and after)

Advisor	After migration 1 (v1.0)	Final	Status
Security: function_search_path_mutable	8 WARN (all 8 functions)	0	OK fixed
Security: authenticated_security_definer_function_executable (0029)	0	16 WARN - the 16 workflow RPCs	WARN intentional: callable by signed-in users only; each enforces role + ownership internally
Security: RLS disabled / policy issues	0	0	OK
Performance: unindexed_foreign_keys	11 INFO	0	OK fixed
Performance: unused_index	23 INFO	30 INFO	INFO expected - no production traffic yet; re-evaluate after real usage

18. Problems encountered and how they were resolved

#	Problem	Cause	Resolution
1	Could not read the schema file in Downloads	Claude Code setting blockReadsOutsideWorkingDirectories	Did not bypass the setting. Asked the user; user copied the file into D:\autotricks_web.
2	Suspected RLS infinite recursion in v1.0 helpers	Review hypothesis	Tested live; disproved; reported the correction honestly. Hardened helpers anyway for search_path and performance.
3	First recursion probe gave false confidence	postgres bypasses RLS; role switch was not proven	Re-ran with current_user and a restricted CLIENT to prove RLS was active.
4	v1.0 had 15 exploitable rule violations despite applying cleanly	Missing guards, broad column grants, policy gaps	Six additive hardening migrations (Sections 6-13).
5	New table would inherit Supabase default grants	Default privileges grant anon/authenticated on new public objects	Explicit REVOKE on vehicle_correction_requests; schema-wide revoke of table/sequence/function privileges in migration 004; verified anon has nothing.
6	Migration ordering risk	004 revokes EXECUTE on all public functions; if 006 ran first, RPC grants would be lost	Applied migrations strictly sequentially in file order.
7	Enum values could not be used in the same transaction	PostgreSQL rule for ALTER TYPE ADD VALUE	Placed new notification values in their own migration 002.

#	Problem	Cause	Resolution
8	Uncertainty about verify_jwt with new API keys	New publishable keys are not JWTs	Checked Supabase docs: public function verify_jwt=false with in-code validation; invite function keeps verify_jwt=true plus getUser check. Confirmed via HTTP tests g/g2/h/i/j.
9	E2E run 1 reported 3 FAILs	Test assertion bug: RLS silently filters UPDATE to 0 rows without error, which the assertion counted as a breach	Focused re-test with row counts and ground-truth read-back proved no data changed; assertions corrected; final run 0 FAIL.
10	E2E report truncated in the middle	Tool output size limit	Re-ran the truncated section separately (21 PASS) and compacted the final report format.
11	Python patch of the test file failed	String escaping in the patch script (not line endings, as first suspected)	Rewrote patch using raw strings; applied successfully.
12	Final E2E run failed to compile	RAISE format 'FAIL=%%' is a literal percent, giving 3 arguments for 2 placeholders	Changed to 'FAIL=% %'; re-ran: 144 PASS / 0 FAIL; file updated.
13	Live HTTP test created a real row	Valid submission test (necessary to prove the endpoint)	Deleted exactly that row (SR-2026-00006, marker name/email). Its SERVICE_REQUEST_CREATED audit entry remains because audit logs are append-only.
14	Test runs consumed reference numbers	Sequences are non-transactional	After final run, guarded restart of all three sequences to 1 (only if no business data).
15	Delete of storage objects via SQL shows a storage trigger error	Supabase blocks direct SQL deletes on storage tables	Recorded honestly: SQL delete test passes via that trigger; via the Storage API the absence of DELETE policies blocks it. UPDATE test proved RLS (0 rows).

19. Cleanup and final database state

Item	Final value
service_requests, clients, profiles, vehicles, products, quotations	0 rows each
notifications / email_notifications	0 / 0
audit_logs	1 (SERVICE_REQUEST_CREATED from the HTTP valid-submission test; append-only)
auth.users	0
storage.objects	0
Reference sequences	restarted; next numbers SR-2026-00001, QT-2026-00001, JOB-2026-00001
Edge Functions	submit-service-request ACTIVE v1; admin-invite-user ACTIVE v1
Migrations recorded	7

To remove the leftover audit row (optional, before go-live) the owner can run as postgres: alter table public.audit_logs disable trigger audit_logs_append_only; delete from public.audit_logs; alter table public.audit_logs enable trigger audit_logs_append_only;

20. Open items, limitations and recommendations

#	Item	Status	Detail / recommendation
1	Email delivery worker	NOT DONE	Queue is populated (QUEUED). A provider (Resend, SMTP, etc.) must be chosen; then a scheduled Edge Function can send and mark SENT/FAILED.
2	PDF generation (quotation PDF, signed quotation PDF, service report)	NOT DONE	Buckets, documents table, owner checks and storage policies are ready.
3	admin-invite-user success path	PARTIAL	Rejection paths HTTP-tested; profile rules SQL-tested. Full invite requires a real admin session and configured SMTP (default Supabase email is heavily rate-limited).
4	Disable public sign-ups	NOT DONE (dashboard)	Authentication settings. Sign-ups currently gain no access but create empty auth users. Not changed automatically because it is a project security setting.
5	First admin	NOT DONE (owner)	Create user in Dashboard, then: insert into public.profiles (id, role, full_name) select id, 'ADMIN', 'Owner Name' from auth.users where email = 'owner@example.com';

#	Item	Status	Detail / recommendation
6	Internal notes visibility	Decision needed	clients.notes and service_requests.admin_notes are visible to the owning client (never to other clients). If internal-only, move them to admin-only tables.
7	Website throttle	PARTIAL	Implemented; not live-tested to avoid creating many rows.
8	Storage via Storage API with user tokens	PARTIAL	Policies tested at SQL level as authenticated roles (the same policies the Storage API enforces); anon Storage API tested over HTTP.
9	Signature image content	Limitation	Bucket enforces image/png and 512 KB; the server cannot prove a PNG was hand-drawn - enforce drawing-only in the UI.
10	Required website fields	Choice made	Backend requires name, phone, make, model, location, description; email, year, chassis, registration are optional but validated. Easy to tighten.
11	Unused indexes	INFO	Re-evaluate after real traffic.
12	Leftover audit row	INFO	See Section 19.

21. Frontend integration guide

21.1 Connection

- Project URL: <https://extsmeyxnzhvcmwyvbi.supabase.co>
- Browser key: publishable key sb_publishable_... (never ship the service role / secret key).
- Types: import Database from supabase/types/database.types.ts and create createClient<Database>(url, key).

21.2 Public website form

```
POST https://extsmeyxnzhvcmwyvbi.supabase.co/functions/v1/submit-service-request
Headers: apikey: <publishable key>, Content-Type: application/json
Body: { customer_name, phone, email?, car_make, car_model, manufacturing_year?,
      chassis_number?, registration_number?, current_location, service_description,
      company_website: "" } // hidden honeypot, leave empty
201 { request_number, submitted_at } | 422 { error, fields } | 429 | 400 | 405
```

21.3 Client signing flow

```
1) rpc('client_accept_quotation_revision',
    { p_revision_id, p_consent_given: true, p_consent_text: '<exact consent text shown>' })
2) canvas -> transparent PNG ->
    storage.from('signatures').upload(`${clientId}/${revisionId}/${uuid}.png`, blob,
    { contentType: 'image/png', upsert: false })
3) rpc('client_sign_quotation_revision', { p_revision_id, p_signature_path })
```

21.4 Direct Data API writes allowed (admin unless noted)

- clients insert/update; vehicles insert/update (not client_id); PHONE service requests with created_by = own user id; request status/admin_notes/linking (before a quotation exists); products insert/update (deactivate instead of delete)
- DRAFT revision discount/tax/notes/terms; DRAFT quotation items insert/update/delete (line_total and totals computed)
- documents insert (after uploading the file); service_jobs.scheduled_at; service_work_items.status
- Any user: profiles.full_name (own); notifications is_read/read_at (own)
- Everything else (statuses, approvals, acceptance, signatures, jobs, revisions) goes through the RPCs in Section 12.

21.5 Realtime

notifications rows are ready for Realtime subscriptions filtered by profile_id; RLS limits each user to their own rows. Enable the table in the Realtime publication when the frontend needs live updates.

22. Files delivered

Path (D:\autotricks_web\...)	Content
AutoTricks_Master_Schema_v1.0.sql	Supplied schema (copied by user)
supabase/migrations/20260913000001_master_schema_v1_0.sql	Migration 1 (unchanged v1.0)
supabase/migrations/20260913000002_notification_types.sql	Migration 2
supabase/migrations/20260913000003_integrity_guards.sql	Migration 3

Path (D:\autotricks_web\...)	Content
supabase/migrations/20260913000004_grants_and_rls.sql	Migration 4
supabase/migrations/20260913000005_audit_and_notifications.sql	Migration 5
supabase/migrations/20260913000006_workflow_rpc.sql	Migration 6
supabase/migrations/20260913000007_storage.sql	Migration 7
supabase/functions/submit-service-request/index.ts	Deployed Edge Function source
supabase/functions/admin-invite-user/index.ts	Deployed Edge Function source
supabase/types/database.types.ts	Generated TypeScript types
supabase/tests/e2e_business_rules.sql	Re-runnable rolled-back end-to-end test suite (144 checks)
supabase/README.md	Integration notes, first-admin bootstrap, RPC list, bucket paths
AutoTricks_Backend_Implementation_Report.pdf	This report

No landing page or other frontend files were created or modified.

23. Final verdict

The AutoTricks Supabase backend is genuinely ready for frontend integration. The schema, security model, Storage, workflow functions and public submission endpoint are deployed, inspected on the live database and verified by 144 passing role-based end-to-end checks plus 15 passing HTTP checks, with all 20 requested business invariants proven.

Before production go-live, complete the open items in Section 20: create the first admin, disable public sign-ups, configure SMTP/email delivery, build PDF generation, decide on internal-notes visibility, and optionally remove the single leftover test audit row.